

External Penetration Testing

Assessment Report

Prepared For: PosBuzz Retail Solutions

Full Name	Md. Abdus Shafi Tahmid
Student ID	2025000000182
Serial Number	12
Course	Applied Penetration Testing Engineer
Submission Date	18/05/2026

Section 1 — Executive Summary

A limited external penetration testing assessment was conducted against authorized TryHackMe training environments on behalf of PosBuzz Retail Solutions. The assessment covered three key areas: active reconnaissance, web application security, and vulnerability exploitation. Multiple security weaknesses were identified including open and unfiltered network services, critical web application flaws such as SQL Injection and Cross-Site Scripting, and a remotely exploitable SMB vulnerability (EternalBlue / MS17-010) that allowed full SYSTEM-level access. Remediation recommendations have been provided for each finding to improve the overall security posture of the environment.

Section 2 — Scope of Assessment

In Scope

- Active Reconnaissance (TryHackMe Room)
- OWASP Juice Shop (TryHackMe Room)
- Blue Room — EternalBlue Exploitation (TryHackMe Room)

Out of Scope

- External production systems
- Any unauthorized targets
- Social engineering or phishing

Section 3 — Methodology

The assessment followed a structured penetration testing methodology across five phases:

- **Reconnaissance:** Passive and active information gathering to identify hosts, open ports, running services, and OS details.
- **Enumeration:** In-depth service enumeration to gather version information and identify potential vulnerabilities.
- **Vulnerability Assessment:** Analysis of discovered services and applications against known CVEs and OWASP Top 10 vulnerabilities.
- **Controlled Exploitation:** Exploitation of confirmed vulnerabilities within the authorized TryHackMe environments only.
- **Documentation:** Recording all findings, evidence, and remediation recommendations in this report.

Section 4 — Active Reconnaissance Summary

Active reconnaissance was performed to map the target environment, discover live hosts, enumerate running services, and identify potential entry points.

Tools Used

Tool	Purpose
Nmap	Port scanning and service/version enumeration
Netcat (nc)	Banner grabbing from open services
Ping / Traceroute	Host discovery and network path mapping

Key Findings

Port	Service	Status	Risk
22	SSH (OpenSSH 7.x)	Open	Medium
80	HTTP (Apache 2.x)	Open	Medium
139 / 445	SMB (Samba)	Open	Critical
3389	RDP	Open	High

Security Impact

- Exposed SSH and RDP services are vulnerable to brute-force and credential stuffing attacks.
- Open SMB ports (139/445) create a significant risk for exploitation, including EternalBlue.
- Version disclosure in HTTP and SSH banners allows attackers to quickly identify known CVEs.
- Lack of network filtering results in an unnecessarily wide attack surface.

Remediation Recommendations

- Restrict access to SSH and RDP using firewall rules (whitelist known IPs only).
- Disable SMBv1 and block ports 139/445 at the network perimeter.
- Suppress version banners on HTTP and SSH services.
- Implement network segmentation and regular port scanning.

Section 5 — OWASP Juice Shop Assessment Summary

A web application security assessment was conducted against the OWASP Juice Shop, targeting common vulnerabilities from the OWASP Top 10. Three significant vulnerabilities were identified.

Finding 1 — SQL Injection (SQLi)

Attribute	Detail
Vulnerability	SQL Injection
Location	Login form (email field)
Payload Used	' OR 1=1--
Severity	Critical

Description

The login form failed to sanitize user-supplied input. By injecting a SQL payload into the email field, it was possible to bypass the authentication mechanism entirely and gain access as the administrator without any valid credentials.

Security Impact

- Full authentication bypass without credentials.
- Unauthorized access to admin panel and all user data.
- Potential to extract or destroy the entire database.

Remediation

- Use parameterized queries and prepared statements for all database operations.
- Validate and sanitize all user inputs on the server side.
- Apply the principle of least privilege to database service accounts.

Finding 2 — Cross-Site Scripting (XSS)

Attribute	Detail
Vulnerability	Reflected Cross-Site Scripting (XSS)
Location	Product search field
Payload Used	<script>alert('XSS')</script>
Severity	High

Description

The product search functionality reflected unsanitized user input directly in the browser response. Injecting a JavaScript payload caused it to execute in the victim's browser, confirming a reflected XSS vulnerability.

Security Impact

- Session cookie theft and account hijacking.
- Redirection of users to phishing pages.
- Execution of malicious actions on behalf of authenticated users.

Remediation

- Encode all user-controlled output rendered in the browser (HTML encoding).
- Implement a strict Content Security Policy (CSP) header.
- Validate and sanitize all inputs on both client and server side.

Finding 3 — Broken Access Control / Weak Authentication

Attribute	Detail
Vulnerability	Broken Access Control + Weak Passwords
Location	User profile endpoints and login
Severity	High

Description

User accounts were found to use weak, easily guessable passwords. Additionally, accessing other users' data was possible by manipulating user IDs in URL parameters, indicating a lack of server-side access control enforcement.

Security Impact

- Accounts can be compromised through brute-force or dictionary attacks.
- Unauthorized access to other users' personal and financial information.
- Privacy violations and potential regulatory non-compliance.

Remediation

- Enforce a strong password policy with minimum length and complexity requirements.
- Implement server-side authorization checks on all sensitive endpoints.
- Enable Multi-Factor Authentication (MFA) for all users.
- Lock accounts after multiple failed login attempts.

Section 6 — Blue Room Exploitation Summary

The Blue Room exercise involved exploiting a Windows machine vulnerable to the EternalBlue (MS17-010) vulnerability. The goal was to demonstrate the impact of running unpatched systems with exposed SMB services.

Vulnerability Details

Attribute	Detail
CVE	CVE-2017-0144
Name	EternalBlue (MS17-010)
Affected Service	SMBv1 (Port 445)
Affected OS	Windows 7 / Windows Server 2008 R2
Severity	Critical (CVSS 9.3)

Exploitation Summary

- **Step 1:** Nmap scan confirmed port 445 was open and the target was running a vulnerable version of SMBv1.
- **Step 2:** The Nmap script ms17-010 confirmed the system was susceptible to EternalBlue.
- **Step 3:** The Metasploit module exploit/windows/smb/ms17_010_eternalblue was used to deliver the exploit payload.
- **Step 4:** A Meterpreter shell was obtained granting SYSTEM-level privileges with no authentication required.
- **Step 5:** Post-exploitation confirmed full access to the file system, credentials, and sensitive data.

Security Impact

- Complete system compromise — SYSTEM-level access allows full control of the target machine.
- Lateral movement risk — the compromised machine can be used to attack other internal systems.
- Data exfiltration — all stored credentials, files, and sensitive data are fully exposed.
- No authentication required — the exploit works without any credentials, maximizing risk.

Remediation Recommendations

- Apply Microsoft patch KB4012212 immediately to remediate MS17-010 on all affected systems.
- Disable SMBv1 across the entire environment using Group Policy or PowerShell.

- Block inbound traffic on ports 139 and 445 at the network perimeter firewall.
- Implement network segmentation to prevent lateral movement in the event of a breach.
- Deploy Endpoint Detection and Response (EDR) tools to detect exploitation attempts.

Section 7 — General Remediation Recommendations

Based on the overall assessment, the following general security improvements are recommended across all systems and applications:

- **Patch Management:** Apply security patches and OS updates regularly on all systems. Prioritize critical CVEs such as EternalBlue.
- **Disable Unnecessary Services:** Audit and disable all services and ports that are not required for business operations.
- **Restrict SMB Access:** Block SMB ports (139/445) at the perimeter firewall and disable SMBv1 entirely.
- **Strong Password Policies:** Enforce minimum 12-character passwords with complexity requirements across all accounts.
- **Multi-Factor Authentication:** Implement MFA on all remote access services including SSH, RDP, and web portals.
- **Input Validation:** Validate and sanitize all user inputs in web applications to prevent injection attacks.
- **Regular Vulnerability Scanning:** Conduct regular internal and external vulnerability scans to proactively identify weaknesses.
- **Security Awareness Training:** Train staff to recognize phishing, social engineering, and other common attack vectors.

Section 8 — Conclusion

The external penetration testing assessment conducted against the authorized TryHackMe environments revealed several significant security weaknesses across network services, web applications, and operating system patching. The most critical finding was the successful exploitation of the EternalBlue vulnerability (MS17-010) resulting in full SYSTEM-level access, which highlights the severe risk posed by unpatched systems running exposed SMB services. Web application testing revealed SQL Injection, Cross-Site Scripting, and Broken Access Control vulnerabilities, all of which could lead to unauthorized data access or account compromise.

Immediate remediation steps should focus on applying outstanding security patches, disabling legacy protocols such as SMBv1, implementing proper input validation in web applications, and restricting unnecessary network service exposure. Following these recommendations will significantly improve the security posture and reduce the overall attack surface. Regular assessments and continuous monitoring are strongly advised to maintain a resilient security posture over time.